

Ethics: The Human Rules of Security Work

The Ethical Lines in Security

Security work is power. You can see everything, control anything, and (with a little effort) break most things. The rules are mostly internal:

Authorization – never touch a system you aren't authorized for (CFAA's blade, plus principle)

Least-privilege-by-choice – access what you need, not what you *can*

Do no harm – don't break production (M10's impact-limits)

Data minimization – handle customer data like a loaded gun

Transparency to the business – no 'secret' security work that surprises the owners

Accountability – your name is on the evidence and the report

Respect humans – security serves people, not machines

The Everyday Dilemmas

"I found the CEO's password in a breach dump – do I look around?" → No. Report the finding, don't weaponize it.

"I can see the intern's browser history via the SIEM" → access ≠ you need it; if you must look, do it as procedure, title it, and explain why.

"My pentest found a hole in a THIRD party's system (through the scope)" → stay in scope; out-of-scope findings get flagged to the client, not exploited.

"Can I 'hack back' the attacker's server?" → NO. Unauthorized access is itself a crime. Defense + reporting, never retaliation.

"Everyone reuses passwords, it's fine to try my colleague's" → never.
Authorization doesn't imply permission to snoop.

The Two-Credit Fantasy (the golden rule)

If you wouldn't want the exact action performed on your own account/data/systems, in the same situation – don't do it to anyone else's. Ethical RAM is short, so encode the rule.

The Analyst's Confession Culture

Good teams treat 'I accidentally saw X' as a **report**, not a sin:

Report early (before it festers)

The harm is hiding it, not the accident

Blame-free reporting = the only culture where mistakes surface (M13's lessons-learned rule)

The Responsibility Escalator

As you gain access (admin, MSSP client SIEMs, cloud root):

Each level = new duty, not new privilege

Document actual ACA (authorized to access) before you click

When in doubt, ask. 'Ask' has saved more careers than skill.

← Security Law: CFAA, GDPR, HI...

Module complete ✓